IT biztonság
2023/2024 tanév ősz

Bemutatkozás



Giesz István
- címzetes egyetemi docens
- okl. Gépészmérnök,
  okl. Rendszerszervező,
  Információbiztonsági menedzser, MSc,
  ISO27001 TÜV Információbiztonság-irányítási vezető auditor
- Információbiztonsági felelős (2013. évi L. trv. szerint)
- KÖFÉM/ALCOA/ARCONIC, BUSZESZ, HUNGRANA, Csemege Julius_Meinl, SPAR, TESCO - IT vezető
- GIRO Zrt – vezérigazgató helyettes

Agenda

- Irányítási rendszerek
- Vonatkozó szabványok
- Jogszabály alapú irányítási rendszerek

… kezdjük az élettel …

- Kis magyar szoftverfejlesztő (Fejlesztő) cég bérbe adná (SaaS) saját fejlesztésű rendszerét egy nagy magyarországi multi közüzemi szolgáltatónak (Közmű).
- Közműre legalább az alábbi jogszabályok vonatkoznak:
  - Infotv. (2011. évi CXII. Információbiztonsági törvény)
  - GDPR
  - Ibtv. (Informatikai biztonsági törvény, számlázási rendszer)
  - Lrtv. (2012. évi CLXVI. Létfontosságú rendszerek törvény)
  - Kibertan.tv. (2023. évi XXIII. Kibertanúsítási törvény)
- A Közmű IT rendszereinek zártnak és megbízhatónak kell lennie, azaz működtetnie kell Információbiztonsági Irányítási Rendszert (IBIR) -> zárt, teljeskörű, folytonos és kockázattal arányos irányítási rendszer.
- Az Ibtv. és Kibertan.tv. kötelezi a Közműt, hogy a beszállítóktól (pl. Fejlesztő) is követelje meg IBIR működtetését.

ENISA FENYEGETÉS TÁJKÉPE (ETL) 2022

The European Union Agency for Cybersecurity - ENISA az Unió ügynöksége, amelynek célja a kiberbiztonság magas szintű közös elérése Európa-szerte.

ENISA - The European Union Agency for Cybersecurity

https://www.arrow.com/ecs-media/16352/fireeye-rpt-mtrends-2021.pdf
https://www.itgovernance.co.uk/blog/list-of-data-breaches-and-cyber-attacks-in-august-2023-79729271-records-breached?utm_source=Email&utm_medium=Macro&utm_campaign=501&utm_content=2023-09-12

Mi az Irányítási Rendszer (IR)?

Egy szervezet **egymással összefüggő vagy kölcsönhatásba lévő elemeinek halmaza a célok eléréséhez szükséges politikák és célkitűzések, valamint folyamatok kialakításához**.

- Egy IR **egy vagy több célt is érinthet**.
- A rendszerelemek magukban foglalják a **szervezet felépítését, szerepét és felelősségét, tervezését és működését**.
- Az IR hatóköre magában foglalhatja a **szervezet egészét, a szervezet meghatározott és azonosított funkcióit, a szervezet meghatározott és azonosított részeit, illetve egy vagy több funkciót egy szervezetcsoporton belül**.
- Az IR komplexitása a szervezettől függ, kisebb cégeknél ez **erős vezetői irányítást**, míg nagy, kiterjedt, bonyolult vállalkozásoknál ez **részletes szabályozási rendszert** jelent.

Információ Biztonság Irányítási Rendszer (IBIR)

Az IBIR

- **politikából, szabályozásból, eljárásokból,** valamint a kapcsolódó **erőforrásokból és tevékenységekből** áll, amelyeket egy szervezet **együtt kezel az információs eszközeinek védelme érdekében;**
- következetes megközelítés a szervezet **információ-biztonságának létrehozására, végrehajtására, működtetésére, nyomon követésére, felülvizsgálatára, fenntartására és javítására** a **szervezet céljainak elérése érdekében;**
- **kockázatértékelésen** és a **szervezet kockázatvállalási szintjén** alapul, amelyek célja a **kockázatok hatékony kezelése**.

Összefüggések …..



Governance, Risk Management, and Compliance (GRC)

Integrált Irányítási Rendszer (IIR)

Olyan rendszer, amely **kettő vagy több** Irányítási Rendszer követelményeit **összevontan** tartalmazza.

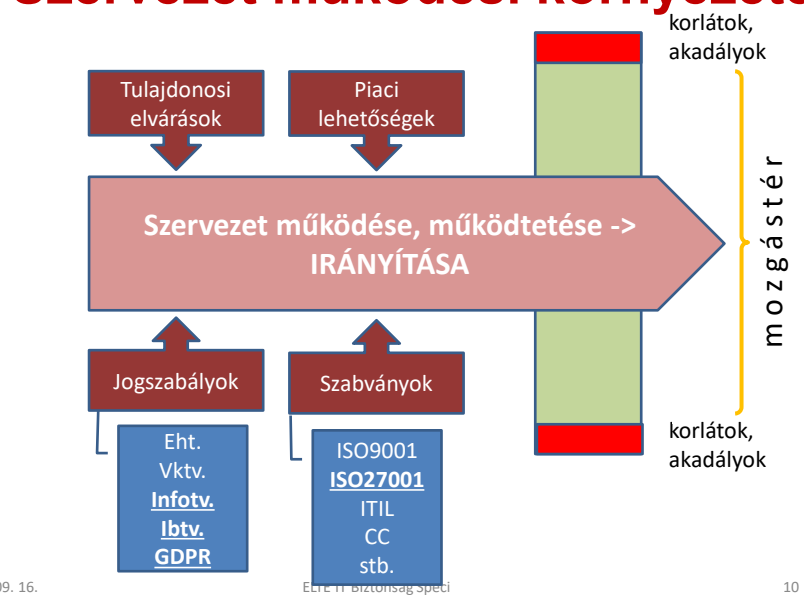
Előnyei:

- gyors, hatékony döntési mechanizmus
- kevesebb papírmunka
- dokumentált
- kontrolált
- erőforrások takaríthatók meg
- PDCA (Plan, Do, Check, Act)
- jobb kommunikáció

Hátrányok:

- hosszú, fáradságos tervezés
- esetleg a már meglévő, gyenge rendszerekre építik rá

Szervezet működési környezete



ISO járatos IIR

ISO 9001:2015 Quality management systems. Requirements
MSZ EN ISO 9001:2015 Minőségirányítási rendszerek. Követelmények

ISO 14001:2015 Environmental management systems. Requirements with guidance for use
MSZ EN ISO 14001:2015 Környezetközpontú irányítási rendszerek. Követelmények alkalmazási útmutatóval

ISO 45001:2018 Occupational health and safety management systems. Requirements.
MSZ EN ISO 45001:2018 A munkahelyi egészségvédelem és biztonság irányítási rendszere (MEBIR). Követelmények.

ISO 50001:2018 Energy management systems. Requirements with guidance for use.
MSZ EN ISO 50001:2019 Energiagazdálkodási irányítási rendszerek. Követelmények alkalmazási útmutatóval.

ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection - Information security management systems - Requirements

ISO - International Organization for Standardization
IEC - International Electrotechnical Commission

További irányítási rendszerek

Szabvány alapú:
NIST (National Institute of Standards and Technology / U.S. Department of Commerce)
- NIST Special Publication 800-100 / Information Security Handbook: A Guide for Managers

BSI (Bundesamt für Sicherheit in der Informationstechnik)
- BSI-Standard 200-1: Information Security Management Systems (ISMS)

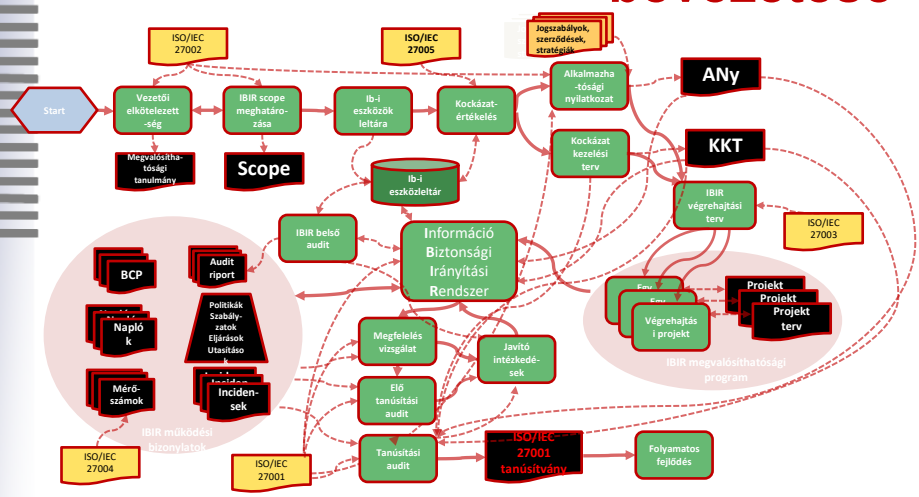
ITIL - Information Technology Infrastructure Library / ISO/IEC 20000 formális és általános szabvány

Jogszabály által meghatározott:
- 2023. évi XXIII. törvény a kiberbiztonsági tanúsításról és a kiberbiztonsági felügyeletről (kibertan.tv.)
- AZ EURÓPAI PARLAMENT ÉS A TANÁCS (EU) 2016/679 RENDELETE (2016. április 27.) (általános adatvédelmi rendelet - GDPR)
- 2013. évi L. törvény az állami és önkormányzati szervek elektronikus információbiztonságáról (Ibtv.)
- 2011. évi CXII. törvény az információs önrendelkezési jogról és az információszabadságról (Infotv.)

Egyéb:
ISACA (Information domains Audit and Control Association)
- COBIT – Control Objectives for Information and Related Technology

TISAX (Trusted Information Security Assessment Exchange) egy speciálisan ISO/IEC 27001-es szabványon alapuló autóipari platform, amellyel az iparági szereplők megoszthatják megrendelőikkel, partnereikkel az információbiztonsági értékelési eredményeiket.

ISO 27001 szerinti IBIR bevezetése



ISO 27001 szerinti IBIR bevezetése

Szabályozási környezet létrehozása. Lényeges, hogy a kiválasztott kontrollokat meg lehessen feleltetni a kockázatértékelési és kockázatkezelési folyamathoz, továbbá a meghatározott politikához és célkitűzésekhez.

A vezetőségnek meg… az IBIR **hatályát** az üzleti tevéken… g jellege, a

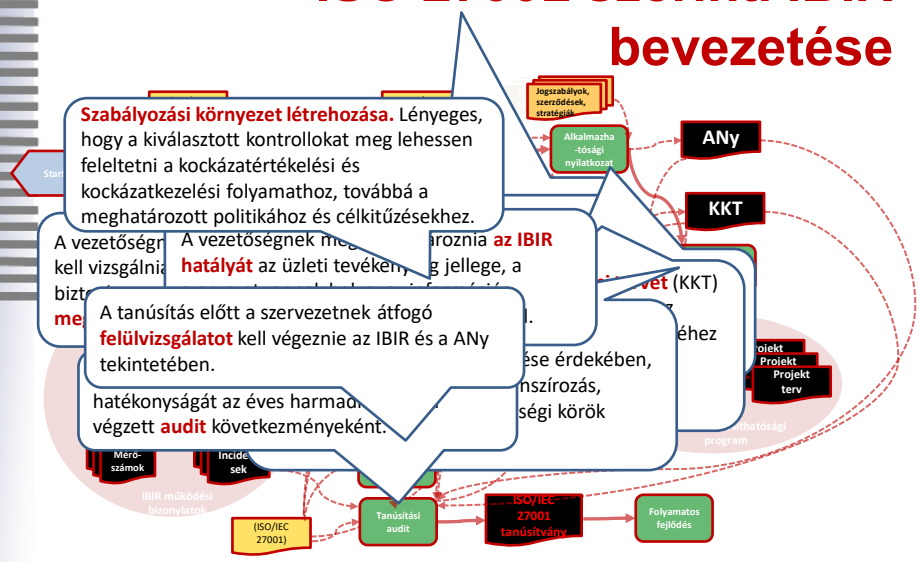
…vet (KKT)

A tanúsítás előtt a szervezetnek átfogó **felülvizsgálatot** kell végeznie az IBIR és a ANy tekintetében.

…éhez

…ése érdekében, …nszírozás, …ségi körök

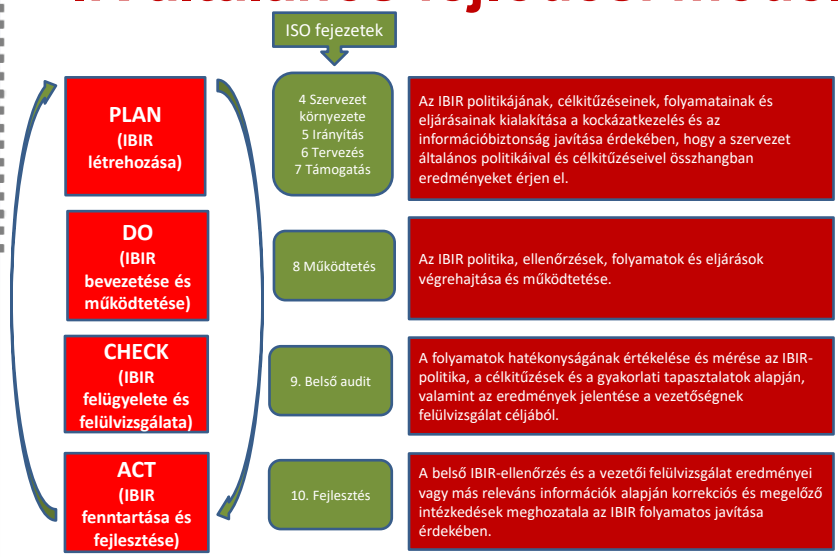
hatékonyságát az éves harmad… végzett **audit** következményeként.



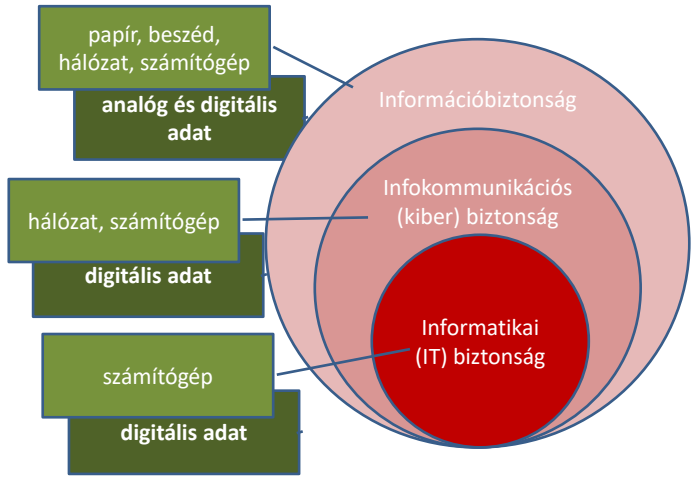
ISO 27001 szerinti IBIR bevezetése

- **ISO27001** formálisan meghatározza, hogyan kell létrehozni egy információbiztonsági irányítási rendszert (IBIR).
- Az **ISO27002** egy „**Code of Practice**", amely számos információbiztonsági kontrollt ajánl. A kontroll célkitűzések a szabványban az információs eszközök biztonságának és védelmének általános, magas szintű üzleti követelményeit tartalmazzák.
- A **vezetésnek** aktívan támogatnia kell az információbiztonságot azáltal, hogy világos irányt ad (pl. szabályozás), demonstrálja a szervezet elkötelezettségét, valamint kifejezetten kijelöli az információbiztonsági feladatokat a megfelelő embereknek.
- A vezetőségnek meg kell határoznia **az IBIR hatályát** az üzleti tevékenység jellege, a szervezet, annak helye, az információs eszközök és technológiák szempontjából.
- **Leltárt** kell készíteni és vezetni az összes fontos információs eszközről és nyilvántartva az összes meghatározó tulajdonságukat.
- A **kockázat értékeléseknek** azonosítaniuk, számszerűsíteniük és rangsorolniuk kell az információbiztonsági kockázatokat a kockázat elfogadásának meghatározott kritériumai és a szervezetre vonatkozó célkitűzések alapján.
- Az **alkalmazási nyilatkozat** (ANy) az IBIR egyik legfontosabb dokumentuma, amely felsorolja a szervezet információbiztonsági célkitűzéseit és a alkalmazandó kontrollokat.
- A szervezetnek **kockázatkezelési tervet** (KKT) kell kidolgoznia, amely meghatározza az információbiztonsági kockázatok kezeléséhez szükséges megfelelő intézkedéseket, erőforrásokat, felelősségi köröket és prioritásokat.
- **Szabályozási környezet létrehozása.** Lényeges, hogy a kiválasztott kontrollokat meg lehessen feleltetni a kockázatértékelési és kockázatkezelési folyamathoz, továbbá a meghatározott politikához és célkitűzésekhez.
- Az **IBIR végrehajtási terv** készítése az azonosított kontroll célok elérése érdekében, amely magában foglalja a finanszírozás, valamint a szerepek és felelősségi körök megosztását is
- A vezetőségnek legalább évente egyszer felül kell vizsgálnia a szervezet ISMS-ét, hogy biztosítsa annak **folyamatos alkalmasságát, megfelelőségét és hatékonyságát**.
- A tanúsítás előtt a szervezetnek átfogó **felülvizsgálatot** kell végeznie az IBIR és a ANy tekintetében.
- A szervezet folyamatosan javítja az IBIR hatékonyságát az éves harmadik fél által végzett **audit** következményeként.

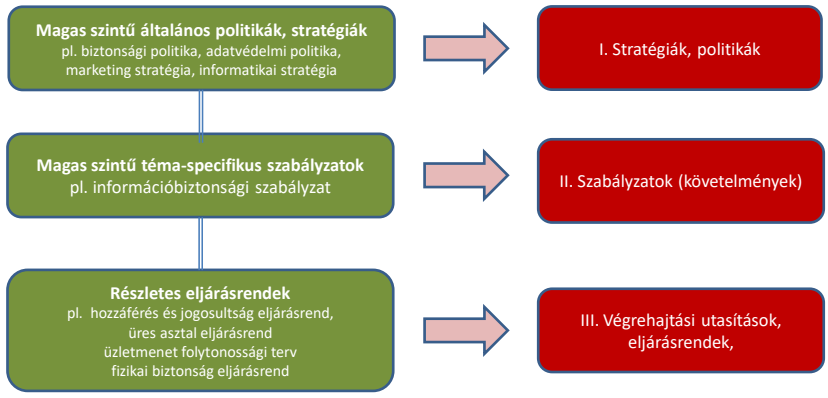
IR általános fejlődési modell



A biztonság különböző szintjei



IR – Szabályozási struktúra



Jogszabályok

Általános jogszabályok

Magyarország Nemzeti Kiberbiztonsági Stratégiájáról szóló 1139/2013. (III. 21.) Korm. határozat

2012. évi CLXVI. törvény a létfontosságú rendszerek és létesítmények azonosításáról, kijelöléséről és védelméről (Lrtv.)

2013. évi L. törvény az állami és önkormányzati szervek elektronikus információbiztonságáról (Ibtv.)

65/2013. (III. 8.) Korm. rendelet a létfontosságú rendszerek és létesítmények azonosításáról, kijelöléséről és védelméről szóló 2012. évi CLXVI. törvény végrehajtásáról

2023. évi XXIII. törvény a kiberbiztonsági tanúsításról és a kiberbiztonsági felügyeletről (kibertan.tv.) (NIS2)

Ágazati jogszabályok példák

42/2015. (III. 12.) Korm. rendelet a pénzügyi intézmények, a biztosítók és a viszont biztosítók, továbbá a befektetési vállalkozások és az árutőzsdei szolgáltatók informatikai rendszerének védelméről

A Magyar Nemzeti Bank 8/2020. (VI.22.) számú ajánlása az informatikai rendszer védelméről

Ágazati jogszabályok

2014. évi XLI. törvény egyes közszolgáltatási tárgyú törvények módosításáról, mint néhány példa

- 2003. évi C. az elektronikus hírközlésről szóló törvény
- 2007. évi LXXXVI. a villamos energiáról szóló törvény
- 2008. évi XL. a földgázellátásról szóló törvény
- 2011. évi CCIX. a víziközmű-szolgáltatásról szóló törvény

„Számla kiállítására csak olyan informatikai rendszer felhasználásával kerülhet sor, amely biztosítja **a díjak hibátlan kiszámítását végző rendszerelemek zártságát, és megakadályozza a számlázási rendszerhez történő jogosulatlan hozzáférést, valamint a számlázási információk észrevétlen módosítását**. A számlázási rendszernek továbbá meg kell felelnie az általános információbiztonsági zártsági követelményeknek is. Ennek érdekében a szolgáltatónak **adminisztratív, fizikai és logikai intézkedésekkel** biztosítani kell „az általános információbiztonsági zártsági követelmények teljesülését.”

Ibtv. származtatása

NIST: National Institute of Standards and Technology (USA)

NIST Special Publication 800-53 Revision 4:
Security and Privacy Controls for Federal Information Systems and Organizations

<https://nvd.nist.gov/800-53/Rev5#>

Ibtv. általános rész

2013. évi L. törvény az állami és önkormányzati szervek elektronikus információbiztonságáról

Tárgyi hatály:
- központi és helyi közigazgatás, önállóan megnevezett szervek, ezek adatfeldolgozói, állami nyilvántartások kezelői, létfontosságú rendszerelemek (és akik ezekkel szerződés keretében adatcserét folytatnak)

Felügyelő hatósága:
- a Nemzetbiztonsági Szakszolgálat, (kivéve polgári nemzetbiztonsági rendszerek, honvédelmi célú rendszerek, kritikus infrastruktúrák esetében)

Adatkezelés helye: Magyarország, esetleg EU/EGK országok

Osztályok, szintek

Biztonsági szintek (1-5)

A végzett tevékenység szerint, saját kockázatelemzés alapján az infokommunikációs rendszerek besorolása

Biztonsági osztályok (1-5)

A követelményeknek való megfelelés állapota a szervezetnél (eltérés felfelé-lefelé a hatóság előzetes engedélyével lehetséges)

- Kétéves tolerancia
- Felülvizsgálati kötelezettség
- Elektronikus információs rendszer biztonságáért felelős személy kinevezése, alkalmazása
- Kijelölt központosított informatikai és elektronikus hírközlési szolgáltató, illetve központi adatkezelő és adatfeldolgozó szolgáltató kötelező igénybe vétele

További eljárásrend

271/2018. (XII. 20.) Korm. rendelet

az eseménykezelő központok feladat- és hatásköréről, valamint a biztonsági események kezelésének és műszaki vizsgálatának, továbbá a sérülékenységvizsgálat lefolytatásának szabályairól

187/2015. (VII. 13.) Korm. rendelet

az elektronikus információs rendszerek biztonsági felügyeletét ellátó hatóságok, valamint az információbiztonsági felügyelő feladat-és hatásköréről, továbbá a zárt célú elektronikus információs rendszerek meghatározásáról

26/2013. (X. 21.) KIM rendelet

az állami és önkormányzati szervek elektronikus információbiztonságáról szóló törvényben meghatározott vezetői és az elektronikus információs rendszer biztonságáért felelős személyek képzésének és továbbképzésének tartalmáról

Biztonsági felügyelet

Kormányzati eseménykezelő központ és az eseménykezelő központok:

CERT/CSIRT funkciókat ellátó szervezet
(központi: NBSZ állományában, ágazati: hatósága mellett)
<https://nbsz.gov.hu/tevekenyseg-mukodes>

NEIH + CERT = Nemzeti Kibervédelmi Intézet (NKI)
<https://nki.gov.hu/hatosag/tartalom/hataskor-ibtv/>

Nemzeti Kiberbiztonsági Koordinációs Tanács:

Egyeztető, véleményező feladatkör

Kiberkoordinátor: a Tanácsot támogatja, „kiber ombudsman”

További eljárásrend

41/2015. (VII. 15.) BM rendelet (Vhr.)

az állami és önkormányzati szervek elektronikus információbiztonságáról szóló 2013. évi L. törvényben meghatározott technológiai biztonsági, valamint a biztonságos információs eszközökre, termékekre, továbbá a biztonsági osztályba és biztonsági szintbe sorolásra vonatkozó követelményekről
<NIST 800-53r4 – Vhr. megfelelés>

Végrehajtási rendelet

Osztályba sorolás és szintek meghatározásának követelményei

1. melléklet:
   Az elektronikus információs rendszerek biztonsági osztályba sorolása - *káralapú meghatározás* -

2. melléklet:
   Az elektronikus információs rendszerrel rendelkező szervezetek vagy szervezeti egységek biztonsági szintbe sorolása - *megfelelés képességi követelményeknek* -

3. melléklet:
   A 4. melléklet „3. Védelmi intézkedés katalógus” alcímben meghatározott védelmi intézkedések besorolásának táblázatai

4. melléklet:
   AZ ADMINISZTRATÍV, FIZIKAI ÉS LOGIKAI BIZTONSÁGI KÖVETELMÉNYEK

Végrehajtási rendelet

Felosztása:
- Öt szint
- Bizalmasság, sértetlenség, rendelkezésre állás
- Adminisztratív, fizikai, logikai intézkedések

<41/2015. (VII. 15.) BM rendelet>

Osztályba sorolás és védelmi intézkedés (OVI) űrlap

Szintbe sorolás és védelmi intézkedés (SZVI) űrlap

Útmutatók az űrlapokhoz

Előnyök

- Jogszabályba foglalt kötelezettség, hatósági felügyelettel
- Pontosan meghatározott biztonsági osztály és szint kategóriák
- Teljeskörű, erőteljes követelménylista
- Excel makrós űrlapokkal támogatott bejelentés, kiértékelés
- Jól kiszámítható megfelelési eredmények
- Cselekvési terv beépíthető (kötelező ígéretek)
- Elvileg a szerződött partnerekkel szemben is érvényesíthető
- Vannak szakmailag kompetens ágazati hatóságok
- Ingyenes bárki számára (mint IBIR)
- Ott van mögötte az NIST
- Büntethető

Hátrányok

- Jogszabállyal nem lehet folyamatosan követni a technológiai fejlődést
- A követelménylista abszolút rugalmatlan, helyettesítő intézkedéseket a hatóság egyenként hagyhat jóvá, szinte nincs is mozgástér
- 1. kategória gyakorlatilag nem létezik,
  5. kategória gyakorlatilag nem teljesíthető
- Meghatározott határidők a megfelelés kialakítására, ami függ a szervezetet felügyelő központi szervtől (minisztériumtól) is, ugyanakkor többéves cselekvési tervet kell létrehozni
- Új létesítések esetén nincs türelmi idő, azonnali megfelelés kell
- Sok az ügyfele a hatóságnak, nem megy helyszínre, nincsenek állásfoglalásai
- A hatály nem egyértelmű (államigazgatási szervek -> költségvetési szervek, adatkezelést végző önkormányzati gazdasági társaságok)

kibertan.tv.

2023. évi XXIII. törvény a kiberbiztonsági tanúsításról és a kiberbiztonsági felügyeletről



tanúsításról és felügyeletről



a tanúsítás



tanúsítási rendszerek

TANÚSÍTÁSI RENDSZEREK	MEGBÍZHATÓSÁGI SZINTEK
érintett termékek és szolgáltatások kategóriái	Alap
kiberbiztonsági követelmények (szabványok vagy műszaki előírások)	Jelentős
az értékelés típusa	Magas
garantált szint	

MINDEN EU TAGÁLLAMBAN AUTOMATIKUSAN EL KELL FOGADNI!

Tervezetek (EU):
- EUCC
- EUCS (European Cybersecurity Certification Scheme for Cloud Services)

Jövő:
- 5g
- IoT

Common Criteria

- nemzetközileg elfogadott **informatikai biztonsági követelményrendszer**
  - közös struktúra és nyelv a termékek/rendszerek az IT követelmények kifejezésére
  - szabványos IT biztonsági követelmény összetevők és csomagok gyűjteménye
- nemzetközileg elfogadott **értékelési módszertan, besorolási rendszer**,
- ISO szabvány (ISO / IEC 15408)
- olyan IT rendszerek és termékek biztonsági tulajdonságainak a specifikációja, melyek a következőket valósítják meg: **bizalmasság, sértetlenség, rendelkezésre állás**,
- **független értékelések eredményeinek az összehasonlíthatóságára**,
- hardverben, szoftverben és förmverben implementált védelmi intézkedésekre vonatkozó
  - technológia független,
  - és a fejlesztő által kívánt kombinációk meghatározására.

felügyelet – érintett szervezetek



felügyelet – érintett szervezetek

Kategória	Főtevékenység	Teljes tevékenységi kör
Kiemelten kockázatos ágazatok	432	528
Kockázatos ágazatok	1247	339
Összesen	1679	867
	2546	



50 & és 10M €

250 & és 50M €

NIS2

Több, mint 50 & vagy 10M €

méretkorlát alóli kivételek



Meghatározott szolgáltatók
nyilvános elektronikus hírközlés, bizalmi szolgáltatók, TLD-nyilvántartók, DNS-szolgáltatók, domainnév-nyilvántartók

Kritikus szervezetek
CER (2022/2557 EU) irányelv alapján azonosított

Köz-szempont
szolgáltatás zavara jelentős hatású lehet a közvédelemre, közegészségre, közbiztonságra

Közigazgatási szerv
nemzeti jog alapján

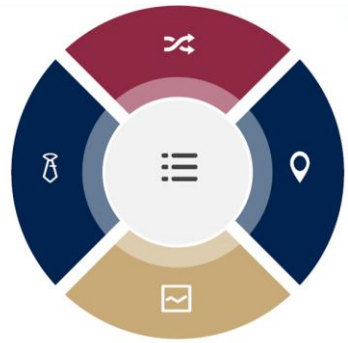
Különös fontosságú
nemzeti vagy regionális szinten

Egyetlen szolgáltatásnyújtó
szolgáltatása a kritikus társadalmi vagy gazdasági tevékenységek fenntartásához elengedhetetlen

érintett szervezetek feladatai

Vezetői feladatok
Biztonságért felelős személy
Szervezeti szabályozások
Tudatosító oktatások és szinten tartás

Biztonsági osztályba sorolás
alap
jelentős
magas



Védelem - mit
Hálózati és információs rendszerek + fizikai környezetük
Adatok/információk
Szolgáltatások

Célok
IBIR
Kockázatelemzés
Védelmi intézkedések
Incidensek megelőzése, kezelése, hatásának csökkentése
BC
Életciklus egészében

hatósági felügyelet (SZTFH)

SZTFH

- Hatósági felügyelet - díj
- Nyilvántartás
- Hatósági ellenőrzés
- Rendkívüli ellenőrzés elrendelése
- Figyelmeztetés
- Eltiltás (egyéb hatóságokkal együttműködve)
- Bírság

Auditorok

- Érintett szervezet felkérésére
- Kiberbiztonsági audit
  - Biztonsági osztályba sorolás
  - Védelmi intézkedések
  - Sérülékenység- és behatolásvizsgálat
  - Kriptográfiai megfelelőség
  - Forráskód-vizsgálat
- Kétévente kötelező

részlet a kibertan.tv-ből

18. § (1) Az érintett szervezet a **kiberfenyegetések által okozható károk mértékével arányos módon köteles gondoskodni a hálózati és információs rendszerei és azok fizikai környezetének a biztonságáról**.

(2) Az (1) bekezdés szerinti biztonság magában foglalja a **hálózati és információs rendszerek, valamint fizikai környezetük védelmét** minden olyan eseménytől, amely veszélyeztetheti

a) a **tárolt, továbbított** vagy **feldolgozott adatok, információk** vagy
b) a hálózati és információs rendszerek által nyújtott vagy azon keresztül elérhető szolgáltatások **bizalmasságát, sértetlenségét és rendelkezésre állását**.

(3) A (2) bekezdésben meghatározott védelemnek ki kell terjednie:

a) az **információbiztonsági irányítás rendszerére**,
b) a hálózati és információs rendszerek **kockázatainak feltárására és kezelésére**,
c) a kockázatok csökkentésére irányuló, a szervezet kockázatelemzésében rendszerenként **meghatározandó biztonsági osztálynak megfelelő adminisztratív, logikai és fizikai intézkedések alkalmazására**,
d) a **biztonsági incidensek megelőzésére, felismerésére, kezelésére és hatásainak csökkentésére**,
e) az **üzletmenet folytonosság biztosítására** és
f) a hálózati és információs rendszerek és az ezek által használt **szoftver és hardver termékek beszerzésére, fejlesztésére, üzemeltetésére**.

és tovább még a 18. §-ban …..

GDPR alapok

Jogi környezet

AZ EURÓPAI PARLAMENT ÉS A TANÁCS (EU) 2016/679 RENDELETE (2016. április 27.)

a **természetes személyeknek** a **személyes adatok kezelése tekintetében** történő védelméről és az ilyen adatok szabad áramlásáról, valamint a 95/46/EK rendelet hatályon kívül helyezéséről

(General Data Protection Regulation / GDPR / Általános Adatvédelmi Rendelet)

Személyes adat

„személyes adat” : azonosított vagy azonosítható **természetes személyre** („érintett”) **vonatkozó bármely információ**; azonosítható az a természetes személy, aki közvetlen vagy közvetett módon, különösen valamely azonosító, például név, szám, helymeghatározó adat, online azonosító vagy a természetes személy testi, fiziológiai, genetikai, szellemi, gazdasági, kulturális vagy szociális azonosságára vonatkozó egy vagy több tényező alapján azonosítható;

(EU) 2016/679 RENDELETE 4. cikk 1.

„személyes adatok különleges kategóriái”: a faji vagy etnikai származásra, politikai véleményre, vallási vagy világnézeti meggyőződésre vagy szakszervezeti tagságra utaló személyes adatok, valamint a természetes személyek egyedi azonosítását célzó genetikai és biometrikus adatok, az egészségügyi adatok és a természetes személyek szexuális életére vagy szexuális irányultságára vonatkozó személyes **adatok kezelése tilos**.

(EU) 2016/679 RENDELETE 9. cikk (1).

Jogi környezet

2011. évi CXII. törvény az információs önrendelkezési jogról és az információszabadságról (Infotv.)

2013. évi L. törvény az állami és önkormányzati szervek elektronikus információbiztonságáról (Ibtv.)

2015. évi CCXXII. törvény az elektronikus ügyintézés és a bizalmi szolgáltatások általános szabályairól (E-ügyintézési tv.)

Alapelvek

„A belső piac megfelelő működése érdekében a **személyes adatok** Unión belüli **szabad áramlását** a természetes személyeknek a személyes adatok kezelése tekintetében történő védelmével összefüggő okokból **nem szabad korlátozni vagy megtiltani**."

= Piac elsődlegessége a személy érdekeivel szemben

„…e rendelet alkalmazása során az uniós intézményeket és szerveket, és a tagállamokat és azok felügyeleti hatóságait ösztönözni kell, hogy vegyék figyelembe a **mikro-, kis-és középvállalkozások sajátos szükségleteit**."

= Jogalkalmazókra bízza a KKV-k problémáját

Alapelvek …

Európában legyenek egységes adatvédelmi szabályok, de hagyjunk helyet a nemzeti sajátosságoknak is!

„Ha e rendelet úgy rendelkezik, hogy a benne foglalt szabályokat tagállami jog által pontosítani, illetve korlátozni lehet, a tagállamok e rendelet egyes elemeit beépíthetik a nemzeti jogukba, …”

„… a rendelet nem zárja ki olyan tagállami jog elfogadását, amely meghatározza a különleges adatkezelési helyzetek körülményeit, ezen belül pontosabban megállapítja, hogy milyen feltételek mellett jogszerű a személyes adatok kezelése.”

Alapelvek …

Európában legyenek egységes adatvédelmi szabályok, de legyen hagyva méltányos hely a nemzeti sajátosságoknak is!

Uniós jog hatályán kívül eső területek:

- nemzetbiztonság, külügy
- igazságszolgáltatás, egyházak adatkezelése mint sajátos kivétel
- anonimizált adatok: statisztika, kutatás
- természetes személy által kizárólag személyes vagy otthoni tevékenység keretében végzett adatkezelés (nem üzleti célok)
- elhunyt személyek adatai

Alapelvek …

Tagállamok további korlátozási lehetőségei!

- honvédelem, közbiztonság
- közérdekű célkitűzések: monetáris, költségvetési, adózási okok, népegészségügy, szociális biztonság
- különleges adatok
- dolgozókkal szembeni etikai eljárások
- érintett személy vagy mások szabadságainak védelme
- polgári jogi követelések érvényesítése

Alapelvek …

Adatkezelés alapjai:

- **Jogszerűség, tisztességes eljárás, átláthatóság**
- **Célhoz kötöttség**
- **Adattakarékosság**
- **Pontosság**
- **Korlátozott tárolhatóság**
- **Integritás és bizalmas jelleg**
- **Elszámoltathatóság**

Érintett jogai

Természetes személy, mint érintett jogai:

- **Átlátható tájékoztatáshoz való jog**
- **Adathozzáférés joga**
- **Helyesbítéshez, törléshez való jog**
- **Az adatkezelés korlátozásához való jog**
- **Az értesülés joga az előbbiekhez**
- **Adathordozhatósághoz való jog**
- **Tiltakozás joga**

Adatkezelő feladatai

Cél: jogszerűség + információbiztonság + folyamatalapú működés együttes biztosítása

- Adatok nyilvántartása
- Adat kezelés biztonságának kialakítása
- Adatvédelmi incidens bejelentése hatósághoz
- Érintettek értesítése incidens esetén
- Hatásvizsgálat
- Előzetes konzultáció hatósággal

Adatkezelési nyilvántartás

Elkészítése:

- Ahány céllal történik adatkezelés, annyi nyilatkozat/tétel/bejegyzés kell...
- Példa: honlapnál fel kell mérni az adatkezelési eseteket, amik előfordulhatnak, úgymint:
  - regisztráció, megrendelés, hírlevél feliratkozás
  - kapcsolatfelvétel (akár űrlapon, akár e-mailben), bármely marketing popup, ahol személyes adatot gyűjtünk (pl. e-mail címért kupon felajánlása, stb.)
  - működési és/vagy marketing sütik telepítése (IP-cím megjegyzése) az oldal látogatásakor
  - nyereményjáték
  - garanciális panaszok, fogyasztóvédelmi panaszok kezelése

… és a tartalom

A nyilvántartásnak tartalmaznia kell:

- A vállalkozás nevét és elérhetőségi adatait
- Az adatfeldolgozás indoklását és az adatkezelés célját
- Az adatalany- és személyesadat-kategóriák ismertetését, tehát az érintettek és a kezelt adatok körét
- Annak tényét, ha történik profilalkotás az érintett kapcsán
- Az adatokat megkapó szervezetek típusait
- Az esetleges adattovábbításra vonatkozó információkat, beleértve a nemzetközi adattovábbításra vonatkozó információkat is
- Felelős személy
- Az adatkezelési műveletek jogalapjait
- Az adatok tárolási/elérési helye
- A kezelt személyes adatok időtartama és/vagy törlésének időpontját, amennyiben az ismert
- Érintett folyamatok, szabályzatok
- Továbbítás harmadik félnek
- Védelmi kontrollok

Jogalapok …

Az adatkezelés jogszerűségéhez - a GDPR 6. cikke alapján - legalább az alábbi jogalapok egyikének fennállása szükséges:

a) **érintett hozzájárulását** adta személyes adatainak egy vagy több konkrét célból történő kezeléséhez;

b) az adatkezelés olyan **szerződés teljesítéséhez** szükséges, amelyben az **érintett az egyik fél**, vagy az a szerződés megkötését megelőzően az **érintett kérésére történő lépések megtételéhez** szükséges;

c) az adatkezelés az adatkezelőre vonatkozó **jogi kötelezettség** teljesítéséhez szükséges;

d) az adatkezelés az érintett vagy egy másik természetes személy **létfontosságú érdekeinek védelme** miatt szükséges;

e) az adatkezelés közérdekű vagy az adatkezelőre ruházott **közhatalmi jogosítvány gyakorlásának** keretében végzett feladat végrehajtásához szükséges;

f) az adatkezelés az adatkezelő vagy egy harmadik fél **jogos érdekeinek** érvényesítéséhez szükséges, kivéve, ha ezen érdekekkel szemben elsőbbséget élveznek az érintett olyan érdekei vagy alapvető jogai és szabadságai, amelyek személyes adatok védelmét teszik szükségessé, különösen, ha az érintett gyermek.

Infotv. módosítása

- Nemzeti hatóság kijelölése
- GDPR által nem szabályozott kérdésekben nemzeti intézkedés meghozatala
- GDPR tartalmában engedélyezett nemzeti pontosítások, szigorítások, korlátozások
- Bűnügyi irányelv kötelező jogharmonizációja
- GDPR hatálya alá nem tartozó kérdések szabályozása az uniós rendelet irányvonala mentén

Hatósági feladatok

GDPR szerinti nemzeti hatóságként lép fel a Nemzeti Adatvédelmi és Információszabadság Hatóság (NAIH)

- Alkalmazza az Európai Adatvédelmi Testület állásfoglalásait, iránymutatásait, saját hatáskörben állásfoglalásokat, iránymutatásokat tesz közzé.
- Tanúsítással és magatartási kódexekkel kapcsolatos követelményeket dolgozz ki.
- Konzultációs lehetőséget biztosít.
- Incidens-és panaszbejelentéseket fogad.
- Hatósági ellenőrzést, vizsgálatot végez.

Hatósági feladatok

Infotv. szerinti hatóságként tevékenykedik

- Az Infotv-ben beépített Bűnügyi Irányelv előírásainak betartását felügyeli.
- Felügyeli a nemzeti hatáskörbe utalt rendeleti előírások megvalósulását.
- Felügyeli az ágazati törvények által szabályozott, a személyes adatok kezelésére vonatkozó előírások megvalósulását.
- Továbbra is ellátja az Infotv-ben rögzített egyéb feladatait.

NAIH aktusok

Hatósági vizsgálatban

- Tájékoztatást kér
- Adatvédelmi auditot folytat
- Tanúsítványokat felülvizsgál
- Minden érintett helyiséghez, eszközhöz, adathoz hozzáfér
- Feltételezett jogsértésekről tájékoztatja az adatkezelőt/adatfeldolgozót

NAIH tevékenységek

Korrekciós hatáskörben

- Figyelmeztet, elmarasztal, utasít
- Elrendel helyreigazítást, tájékoztatást
- Adatkezelést korlátoz, megtilt, adatáramlást
- megakadályoz
- Tanúsítványt visszavon/visszavonat
- Közigazgatási bírságot szab ki

NAIH tevékenységek

Engedélyezés, tanácsadás hatáskörben

- Konzultál és tanácsot ad az adatkezelőnek
- Véleményt alkot és nyilvánosságra hoz
- Adatkezelést engedélyez, ha szükséges
- Tanúsítványt visszavon/visszavonat
- Tanúsítási rendszert, magatartási kódexet hagy jóvá
- Részt vesz tanúsító akkreditálásában

<https://naih.hu>

Elegendő biztonság

- Bizalmasság, sértetlenség, rendelkezésre állás, ellenálló képesség biztosítása
- Követhetőség, elszámoltathatóság az adatkezelési folyamatokban (pl. törlés, zárolás)
- Rendszeres, dokumentált belső ellenőrzés/audit/kockázatkezelés
- Személyes adatok álnevesítése, titkosítása
- Intézkedések, korlátozások egyes adatkezelési eseményekre
- Megfelelés igazolásához felhasználható:
  - magatartási kódexhez való csatlakozás (nem közhatalmi szervek esetén), ha lesz ilyen
  - tanúsítási mechanizmushoz történt csatlakozás, ha lesz

Megoldás, alapszint

Fizikai hozzáférés-védelem
Adminisztratív szabályok (szabályzat)
Logikai védelem

- felhasználó azonosítás, jogosultságkezelés
- titkosítás
- anonimizálás
- adatszivárgás megelőzése
- ÜFT/Mentés
- incidenskezelés
- adatkezelési aktusok támogatása
- naplózás

Adatkezelés

”a személyes adatokon vagy adatállományokon automatizált vagy nem automatizált módon végzett bármely művelet vagy műveletek összessége, így a gyűjtés, rögzítés, rendszerezés, tagolás, tárolás, átalakítás vagy megváltoztatás, lekérdezés, **betekintés**, felhasználás, közlés továbbítás, terjesztés vagy egyéb módon történő hozzáférhetővé tétel útján, összehangolás vagy összekapcsolás, korlátozás, törlés, illetve megsemmisítés”

(EU) 2016/679 RENDELETE 4. cikk 2.

„az alkalmazott eljárástól függetlenül az adatokon végzett bármely művelet vagy a műveletek összessége, így különösen az adatok gyűjtése, felvétele, rögzítése, rendszerezése, tárolása, megváltoztatása, felhasználása, lekérdezése, továbbítása, nyilvánosságra hozatala, összehangolása vagy összekapcsolása, zárolása, törlése és megsemmisítése, valamint az adatok további felhasználásának megakadályozása, fénykép-, hang- vagy képfelvétel készítése, valamint a személy azonosítására alkalmas fizikai jellemzők rögzítése”

2013. évi L. törvény

Sokat segíthet

2013. évi L. tv. (Ibtv.) szerinti megfelelés

Minőségirányítási rendszerek, információbiztonsági szabványok bevezetése, elsősorban ISO 2700x, NIST 800-53, ISO 9001

IIR rendszer ez is: Eht/Ibtv + Ibtv/Lrtv + GDPR + ISO27001 tanúsítás

SAP vállalati folyamatirányítás

A dokumentumkészletet lefedő iratkezelési rendszer

Irányítási rendszer, azon belül a Compliance működése

Jó kapcsolat tanácsadó cégekkel, mint partnerekkel

Olvasnivalók

Célszerű a hivatkozott honlapokon körülnézni és a dokumentumokba belenézni.